Megasub - Backend Fixes

Items from the tester feedback report (Megasub_Test_Feedback.pdf) that can only be fixed on the API at mega-sub.com/api/v1/external. Page numbers refer to that report. Everything that could be fixed in the mobile app has already been changed (see the last section).

Summary - 17 fixes: 7 critical, 7 high, 3 medium

ID	Fix	Severity	Tester issue
BE-01	Block unverified emails from using the account	Critical	ONB-001 (p2)
BE-02	Enforce phone verification server-side	Critical	ONB-002 (p2)
BE-03	One phone number per account; anti-abuse	Critical	ONB-003 (p2)
BE-04	Check the transaction PIN on every PIN-gated call	Critical	SEC-001 (p27)
BE-05	Fix set_transaction_pin, and stop it overwriting an existing PIN	Critical	PAY-003 (p17)
BE-06	Server-side duplicate purchase prevention	Critical	PAY-003 (p17)
BE-07	Turn KYC on	Critical	KYC-001 (p10), ONB-004 (p3)
BE-08	Return the real reason instead of a 5xx	High	ONB-006 (p5), PAY-007 (p22), PAY-008 (p23), PAY-009 (p24), UI-005 (p31)
BE-09	Enforce validatephonenetwork	High	PAY-005 (p19)
BE-10	Expose and explain minimum/maximum amounts	High	PAY-006 (p20-21)
BE-11	Log in with username or phone number	High	ONB-008 (p7)
BE-12	Include wallet funding in transaction history	High	WAL-002 (p13)
BE-13	Never return demo results as real purchases	High	PAY-001 (p14-15)
BE-14	Confirm the NGN 5,000 airtime daily limit	High	PAY-002 (p16)
BE-15	Make delivery fast and report its status	Medium	PAY-011 (p26)
BE-16	Coupons: correct counts and network rules	Medium	UI-006 (p32)
BE-17	BVN lookup should prefill identity details	Medium	ONB-005 (p4)

Suggested order: BE-01 to BE-06 first (security and money), then BE-08, because one change to error responses fixes five tester issues, then the rest.

Critical

BE-01 - Block unverified emails from using the account

Critical

Tester issue	ONB-001 (p2)
Problem	A new account gets a working login token from register before the email is confirmed. Testers backed out of the Verify Email screen and were then able to use the dashboard and get an account number.
What we see	`register` returns a token straight away. `/login`, `/dashboard` and `generate_naira_virtual_accounts` all work for an unverified account.
Change needed	Until `confirm_email_verification` succeeds, refuse every endpoint except `email_verification` / `confirm_email_verification` with HTTP 403 and `code: EMAIL_NOT_VERIFIED`. Return `email_verified` (true/false) in the user object of `/login` and `/dashboard`. Never create a funding account for an unverified user.
Done when	An unverified account cannot load the dashboard, buy anything or receive an account number, on any device, even if the app is modified.

BE-02 - Enforce phone verification server-side

Critical

Tester issue	ONB-002 (p2)
Problem	Phone verification can be skipped and the account still works.
What we see	`confirm_phone_verification` answers `status: true` even for a code it did not accept; the only signal is `data.verified`, and some replies omit it.
Change needed	Return HTTP 422 with `status: false` for a wrong or expired code, and always include `data.verified`. Store the verified state on the user and return `phone_verified` on `/login` and `/dashboard`. Apply the unverified-phone limits to every purchase endpoint.
Done when	A wrong code is rejected with a clear message, and an account with no verified phone is limited no matter what the app sends.

BE-03 - One phone number per account; anti-abuse

Critical

Tester issue	ONB-003 (p2)
Problem	The same temporary phone number was used to sign up several accounts.
What we see	`phone_verification` accepts a number already verified on another account.
Change needed	Make the verified phone number unique across accounts (normalise 0XXXXXXXXXX, 234XXXXXXXXXX and +234XXXXXXXXXX to one form first). Rate-limit OTP sends per number, per device and per IP. Consider blocking known virtual/temporary number ranges.
Done when	Verifying a number already linked to another account fails with "This phone number is already in use."

BE-04 - Check the transaction PIN on every PIN-gated call

Critical

Tester issue	SEC-001 (p27)
Problem	A wrong transaction PIN still opened the Top-up screen (dedicated funding account details).
What we see	The app only unlocks Top-up when `fetch_naira_virtual_accounts` accepts the PIN, so that endpoint is accepting wrong PINs.
Change needed	Verify the PIN on `fetch_naira_virtual_accounts`, `fetch_user_naira_funding_transactions`, every `buy_*` call, `scheduled_purchases`, card calls and account generation. Reply to a wrong PIN with HTTP 403, `code: INVALID_PIN`, "Incorrect PIN", and attempts remaining. Lock PIN use for 30 minutes after 5 wrong tries.
Done when	A wrong PIN is always refused, and repeated wrong PINs lock the account temporarily.

BE-05 - Fix set_transaction_pin, and stop it overwriting an existing PIN

Critical

Tester issue	PAY-003 (p17)
Problem	Setting a PIN failed with the raw text "validation.integer (and 1 more error)". The app also calls this same endpoint to change a PIN, so anyone holding a session can replace the PIN without knowing the old one.
What we see	The app sends `{ user_id, pin, confirm_pin }` as 4-digit strings. "validation.integer" with 2 errors suggests both fields failed an `integer` rule; PHP rejects integers with a leading zero (e.g. "0123"). The message is also untranslated because the Laravel language file is missing.
Change needed	Validate as `required|string|digits:4` and `same:pin`; never cast to integer, or PINs starting with 0 break. Add `lang/en/validation.php` so no raw keys reach users. When a PIN already exists, require the current PIN (or the `forgot_pin` OTP) to change it, and return `pin_set: true` on `/login` / `/dashboard` so the app never asks an existing user to "set" one.
Done when	PIN "0123" can be set, errors read as plain English, and an existing PIN can only change with the old PIN or an OTP.

BE-06 - Server-side duplicate purchase prevention

Critical

Tester issue	PAY-003 (p17)
Problem	There is no duplicate-transaction prevention.
What we see	Retrying the same purchase charges again. The app now blocks double taps on the device, but retries after a timeout, two devices or a modified client are not covered.
Change needed	Accept a `client_reference` (UUID) on every `buy_*`, `scheduled_purchases`, `fund_card` and treat a repeat as the same transaction (return the original result). Also reject the same product, recipient and amount from the same user within 60 seconds unless the user confirms.
Done when	The same purchase sent twice results in one charge and one delivery.

BE-07 - Turn KYC on

Critical

Tester issue	KYC-001 (p10), ONB-004 (p3)
Problem	BVN KYC shows "Verification Is Off" and Card KYC shows "Verification Coming Soon / Card KYC could not be submitted".
What we see	`fetch_kyc_status` reports KYC disabled and `submit_card_kyc` returns the unavailable response.
Change needed	Enable the KYC provider in production and test success, failure, retry and pending states end to end.
Done when	A tester can complete BVN and card KYC, and sees a specific result for each state.

High

BE-08 - Return the real reason instead of a 5xx

High

Tester issue	ONB-006 (p5), PAY-007 (p22), PAY-008 (p23), PAY-009 (p24), UI-005 (p31)
Problem	Rate limits, insufficient balance, network mismatch and meter validation failures all reached users as "Megasub's servers aren't responding".
What we see	These cases come back as HTTP 500 with "Server Error", so the app cannot tell them apart from an outage.
Change needed	Use 4xx codes with a clear message and a machine code: 429 + Retry-After for OTP/rate limits ("Too many attempts. Please wait 60 seconds."); 422 `INSUFFICIENT_BALANCE`; 422 `NETWORK_MISMATCH`; 422 `INVALID_METER` from `validate_meter`; 503 `PROVIDER_UNAVAILABLE` naming the provider when upstream is down. Keep 500 only for real crashes, and log the cause.
Done when	Each failure tells the user what went wrong and what to do; 500s are rare and alerted on.

BE-09 - Enforce validatephonenetwork

High

Tester issue	PAY-005 (p19)
Problem	An MTN recharge to a Glo number (0705...) went through and reported success.
What we see	The app sends `validatephonenetwork: 1` on `buy_airtime` / `buy_data`, but the mismatch is not caught (for data it crashes with a 500 instead, see BE-08).
Change needed	When `validatephonenetwork = 1`, check the number against the selected network (provider lookup, so ported numbers work) and reply 422 `NETWORK_MISMATCH` before charging. Scheduled purchases currently send 0; decide if they should validate.
Done when	A mismatched number is refused before any money moves, with a message naming the network.

BE-10 - Expose and explain minimum/maximum amounts

High

Tester issue	PAY-006 (p20-21)
Problem	An airtime amount of NGN 26 failed with just "Validation failed".
What we see	The 422 carries no useful text and `fetch_product_plans` has no amount limits.
Change needed	Add `minimum_amount` and `maximum_amount` to each plan in `fetch_product_plans`. Reject out-of-range amounts with 422 and `errors.amount`: "The minimum airtime amount is NGN 50." The app now assumes NGN 50 and switches to the plan values as soon as they appear.
Done when	The app shows the real minimum before submit, and the error names the limit.

BE-11 - Log in with username or phone number

High

Tester issue	ONB-008 (p7)
Problem	Only email works at login.
What we see	The app already sends whatever was typed as `identifier` to `/login`.
Change needed	Match identifier against email, username and phone (normalised as in BE-03). Keep the same error for "not found" and "wrong password".
Done when	Email, username and phone number all log in to the same account.

BE-12 - Include wallet funding in transaction history

High

Tester issue	WAL-002 (p13)
Problem	Wallet funding shows only in notifications, not in Wallet or History.
What we see	Funding credits are only available from `fetch_user_naira_funding_transactions`, which needs the PIN. The app now offers a "Show wallet funding" option behind the PIN as a stopgap.
Change needed	Return funding credits in `fetch_transactions` (category `wallet_funding`) with amount, date, status, reference and bank, without needing the PIN. Balances and credits are not more sensitive than purchases.
Done when	Every top-up appears in Wallet and History alongside purchases.

BE-13 - Never return demo results as real purchases

High

Tester issue	PAY-001 (p14-15)
Problem	A WAEC result checker purchase "succeeded" with PIN 1234 and serial waec-serial4. An eSIM failed with "Insufficient USD wallet balance" although the naira wallet was funded.
What we see	`buy_result_checker` returned demo values with `status: true`. eSIM is charged only from the USD wallet, which users have no clear way to fund.
Change needed	A product not live with its provider must reply 503 with `data.available: false` and must not charge. For eSIM, either convert from the naira wallet at checkout or provide a USD funding route, and say which in the error.
Done when	No user ever receives a demo PIN, and an eSIM purchase can be completed by a normal funded user.

BE-14 - Confirm the NGN 5,000 airtime daily limit

High

Tester issue	PAY-002 (p16)
Problem	Testers saw a daily-limit message for the first time.
What we see	"This airtime purchase exceeds your NGN 5,000.00 daily limit" comes from the server.
Change needed	Confirm the limit with product. Expose limits (daily cap, remaining today, unverified-phone cap) in an endpoint such as /dashboard so the app can show them before the user tries to pay.
Done when	Limits are intended, documented, and visible before a purchase fails.

Medium

BE-15 - Make delivery fast and report its status

Medium

Tester issue	PAY-011 (p26)
Problem	Delivery takes several minutes.
What we see	No timing data is available to the app.
Change needed	Measure time from charge to provider confirmation per product and provider. Move slow provider calls to a queue, return `status: pending` at once, and push/notify on completion. Set and monitor a target (e.g. 95% within 30 s for airtime/data).
Done when	Delivery time is measured, most purchases complete within the target, and slow ones show as pending.

BE-16 - Coupons: correct counts and network rules

Medium

Tester issue	UI-006 (p32)
Problem	A coupon's "10 left" never changed after use; an MTN SME coupon was offered and "qualified" while GLO was selected.
What we see	`check_coupon_qualification` takes only user_id and code, so it cannot check the network or plan. The app now hides coupons whose `product_plan_category.network.id` doesn't match the selected network.
Change needed	Accept `network_id` and `product_plan_id` in `check_coupon_qualification` and reject non-matching purchases. Decrease `slots_remaining` when a discounted purchase succeeds, and always include the network id in `fetch_active_coupons`.
Done when	A coupon only qualifies for its own network/plan, and its count drops after each use.

BE-17 - BVN lookup should prefill identity details

Medium

Tester issue	ONB-005 (p4)
Problem	Users type out details the BVN should already provide.
What we see	`verify_bvn` exists but its reply isn't usable to prefill the Card KYC form, and KYC is off (BE-07).
Change needed	Return first name, last name, date of birth and phone from the BVN lookup in a fixed shape, and allow only permitted corrections on submit.
Done when	After entering a BVN, the form fills itself and the user only reviews it.

Already changed in the app

These app changes depend on the API fields named here; please keep them stable or tell the mobile team if they change.

Login / fingerprint	Unfinished signups resume at Verify Email / Verify Phone. The app reads `email_verified` or `email_verified_at` from /login and /dashboard if present.
Error messages	Any specific message the server sends is shown, even on a 5xx. Generic "Server Error" text still shows the outage line. 429 shows a wait and uses Retry-After. A 422 shows the first entry of errors{}, and untranslated validation.* keys are turned into plain English.
Duplicate taps	An identical `buy_*` / scheduled / card POST already in flight is not sent a second time.
Amounts	Minimum NGN 50 shown and enforced for airtime until `minimum_amount` arrives on plans.
Coupons	Filtered by `product_plan_category.network.id` (or `network_id`).
Wallet funding	Wallet can show funding credits after a PIN, using `fetch_user_naira_funding_transactions`.